

This document presents a structured risk assessment for iBank Financials using established frameworks and a standardized assessment process. It identifies critical assets, evaluates associated threats and vulnerabilities, and determines risk levels based on the likelihood and impact to confidentiality, integrity, and availability.

Risk Assessment

Group 1

Kayla Hodge
Mark VanDike
Justin Vandrunen
Jarred Ward
Jordan Wicks

1. The steps to complete a generic risk assessment:

- **Determine the scope**

Define what systems, data, and processes are included. Review the standards and frameworks that guide the company and avoid relying only on a checklist approach.

- **Look at the risk equation**

Identify IT assets and their value. Identify threats (possible dangers) and vulnerabilities (weaknesses). Determine how likely each threat is to exploit a vulnerability and ask what could go wrong.

- **Analyze the risks and determine impact**

Use a Likert scale to measure likelihood (1 = Improbable to 5 = Frequent). Evaluate the impact to confidentiality, integrity, and availability (1 = Negligible to 5 = Catastrophic). Calculate the risk score.

- **Determine and prioritize the risks**

Focus on risks above the organization's tolerance level. Decide whether to avoid, transfer, or mitigate the risk. Accept that some residual risk will remain.

- **Document the risks in a risk register**

Record all risks and review them regularly. Include the risk scenario, identification date, existing controls, and current risk level.

2. The framework(s) to use to guide the decisions while performing a risk assessment for iBank Financials:

- **Primary Framework: NIST RMF**

NIST RMF is the primary framework used because it directly aligns with the risk assessment process shown in the lecture and outlined in Question 1. It supports defining scope, identifying assets, analyzing threats and vulnerabilities, determining likelihood and impact, and prioritizing risks. The framework also emphasizes continuous monitoring, which fits well with the use of a risk register and ongoing risk management. It is well suited for iBank's mixed environment of cloud and on-prem systems and supports future control implementation and auditing.

- **Supporting Framework: ISO 31000**

ISO 31000 is used to provide a broader business perspective on risk. While the main process focuses on technical risk, ISO 31000 ensures that risks are also evaluated based on business impact, such as financial loss and operational disruption. This is important for iBank because its services directly affect customers and financial transactions. It helps translate technical findings into business-level decisions.

- **Supporting Framework: FAIR**

FAIR is included to add a financial perspective to the risk assessment. It helps estimate potential monetary loss from identified risks rather than relying only on qualitative ratings. This is useful for iBank because it operates in the financial sector and needs to understand the financial impact of security events. It supports better prioritization and helps justify security investments.

- **Supporting Framework: OCTAVE**

OCTAVE is included because it closely aligns with the risk assessment process used in this assignment. It focuses on identifying critical assets, evaluating threats, and analyzing vulnerabilities from an organizational perspective. This matches the lecture approach of using the risk equation and prioritizing risks based on likelihood and impact. OCTAVE is especially useful for understanding how risks affect business operations, not just technical systems. It complements NIST RMF by reinforcing a structured, asset-focused risk analysis.

- **Supporting Framework: COBIT**

COBIT is relevant because it focuses on IT governance, control management, and accountability. In this case, the access control issue was not just a technical failure, but a governance failure where leadership bypassed proper security practices. COBIT emphasizes defined roles, least privilege, and management oversight to ensure that access decisions follow established policies. This would have prevented the president from granting full access without proper review or control enforcement.

- **Compliance Framework: PCI DSS**

PCI DSS is included because iBank stores and processes credit card data. It does not drive the full risk assessment process, but it provides required security controls that must be considered. These include protections such as encryption, access control, and monitoring. Including PCI DSS ensures that regulatory and compliance risks are addressed alongside technical risks.

- **Compliance Framework: NYDFS 23 NYCRR 500**

NYDFS 23 NYCRR 500 is included because iBank Financials is a New York operated financial institution. This framework sets specific standards for protecting consumer data and risk assessment. These protections include aspects such as encryption, Multi-Factor Authentication (MFA), Access Control, and Data Retention. Including this framework strengthens iBank Financials security posture, reduces the risk of potential breaches, and improves trust between customers and stakeholders.

- **Compliance Framework: Sarbanes-Oxley Act (SOX)**

The SOX framework is included because iBank Financials could potentially handle large amounts of currency. This framework is intended to ensure accurate financial reporting and to prevent any fraudulent acts. This framework holds individuals accountable for financial reports and enhances accuracy from stiff criminal penalties.

- **Compliance Framework: KYC (Know Your Customer)**

The KYC framework is included because iBank Financials has recently added cryptocurrency investing services. This framework verifies client identification and assesses risks to prevent crimes such as money laundering. This framework uses customer identification and due diligence processes for evaluating the risk of customer accounts and verifying customer identities. Including this framework ensures regulatory compliance, protects iBank Financials reputation, prevents financial crimes from occurring, and mitigates institutional risk.

These frameworks work together to provide a comprehensive approach to risk assessment. NIST RMF establishes the overall structure and lifecycle for managing risk, while NIST-aligned methods, such as those used in OCTAVE, support detailed identification and analysis of assets, threats, and vulnerabilities. ISO 31000 ensures that risks are evaluated from a business perspective, and FAIR adds financial context to support decision-making. PCI DSS ensures that regulatory requirements related to payment data are addressed. Together, these frameworks allow iBank Financials to assess risk from technical, operational, and compliance perspectives.

A Risk Assessment for iBank Financials

- **Client Management System (Server/AWS)**

Asset: Core system used for managing client accounts and financial services

How it is used: Supports client account management, financial transactions, and service delivery.

Importance: Critical to daily operations and handling sensitive financial data.

Threats: External attackers, unauthorized access, system outages

Vulnerabilities: Internet exposure, reliance on VPN, potential misconfigurations

Explanation: This system supports critical business functions and is accessed frequently by employees. Because it is exposed through VPN and cloud services, it presents multiple entry points for attackers. A successful attack could disrupt operations and expose sensitive financial data. This makes it both highly likely to be targeted and highly impactful if compromised.

- **Customer Financial Data (PII and credit cards)**

Asset: Sensitive customer data stored and processed by the company

How it is used: Stores and processes customer personal and financial information for transactions and account services.

Importance: Critical due to regulatory requirements and sensitivity of financial data.

Threats: Data breaches, insider misuse, malware

Vulnerabilities: Stored credit card data, excessive access permissions

Explanation: This data is extremely valuable and is processed regularly, making it a primary target for attackers. The presence of stored credit card data increases compliance and security risks. Misconfigured access controls further increase the likelihood of exposure. A breach would result in severe financial, legal, and reputational consequences.

- **Shared Wireless Network**

Asset: Network infrastructure shared with another company

How it is used: Provides network connectivity for internal users and a partnered external organization.

Importance: High, as it directly connects to internal systems and introduces external exposure.

Threats: Unauthorized access, eavesdropping, lateral movement

Vulnerabilities: Lack of segmentation, shared access with external users

Explanation: Sharing a network with another organization weakens the security boundary. Without proper segmentation, attackers or unauthorized users could move laterally into internal systems. This increases the chance of data interception or unauthorized access. The impact is significant because it could expose internal communications and systems.

- **Employee Laptops (Remote Devices)**

Asset: Devices used by employees to access internal systems

How it is used: Enables employees to access internal systems remotely and perform daily job functions.

Importance: High, as these devices serve as access points into the internal network.

Threats: Device compromise, phishing, data leakage

Vulnerabilities: Use of personal devices, unsecured networks

Explanation: These devices are frequently used outside of controlled environments, increasing exposure to threats. Personal devices may not have proper security controls or monitoring in place. This makes them more vulnerable to malware and phishing attacks. If compromised, they could provide attackers with access to internal systems and data.

- **VPN Infrastructure**

Asset: Secure access point for remote connections

How it is used: Provides secure remote access to internal systems and applications.

Importance: Critical, as it acts as a gateway to sensitive internal resources.

Threats: Credential theft, unauthorized access

Vulnerabilities: Single point of entry, possible weak authentication

Explanation: The VPN acts as a gateway into internal systems, making it a high-value target. If credentials are compromised, attackers could bypass perimeter defenses. Weak authentication or lack of multi-factor authentication increases this risk. The impact is severe because it could expose multiple internal systems at once.

- **Access Control System**

Asset: Identity and access management system

How it is used: Manages user authentication and authorization across systems.

Importance: Critical, as it controls access to all systems and data.

Threats: Insider threats, privilege abuse

Vulnerabilities: Misconfigured permissions (full access granted)

Explanation: The current configuration violates the principle of least privilege. Giving all employees full access significantly increases the risk of misuse or accidental

damage. Insider threats become much more likely under these conditions. The impact is severe because it affects all systems and sensitive data.

- **New Employee Workstations**

Asset: Newly deployed employee systems

How it is used: Allows new employees to access systems and perform assigned tasks.

Importance: Medium-High, as these systems provide access to internal resources.

Threats: Malware, unauthorized access

Vulnerabilities: Missing security configurations, lack of monitoring

Explanation: These systems were deployed quickly without proper security setup. This increases the chance that vulnerabilities exist, such as missing patches or weak configurations. While they are not as critical as core systems, they still provide access to internal resources. This makes them a potential entry point for attackers.

- **Cloud Infrastructure (AWS)**

Asset: Cloud-hosted systems and storage

How it is used: Hosts applications, storage, and services supporting business operations.

Importance: High, as it supports scalable infrastructure and data storage.

Threats: Misconfiguration attacks, unauthorized access

Vulnerabilities: Misconfigured services, weak IAM controls

Explanation: Cloud environments are flexible but can be risky if not configured properly. Misconfigured storage or access controls can expose large amounts of data. Attackers often target cloud services for this reason. The impact is high because it could affect multiple systems and datasets at once.

- **Authentication Systems**

Asset: System managing user authentication and access

How it is used: Verifies user identities and grants access to systems.

Importance: Critical, as it protects access to all organizational resources.

Threats: Credential compromise, identity attacks

Vulnerabilities: Centralized access control, lack of strong authentication

Explanation: This system controls access across the environment, making it a critical component. If compromised, attackers could gain access to multiple systems. Weak authentication mechanisms increase the likelihood of this happening. The impact is severe because it affects overall system security.

- **Payment Processing System**

Asset: Processes financial transactions for customers

How it is used: Handles payments through credit cards, bank transfers, and other financial methods.

Importance: Critical due to financial operations and PCI compliance requirements.

Threats: Fraud, data breaches

Vulnerabilities: Stored credit card data, daily batch processing

Explanation: This system processes sensitive financial transactions daily. The storage of credit card data increases the risk of fraud and regulatory violations. A compromise could result in financial loss and compliance penalties.

- **Vendor Applications**

Asset: Third-party systems supporting operations

How it is used: Supports business operations through third-party services and integrations.

Importance: Medium-High, as a compromise could impact internal systems and data.

Threats: Supply chain attacks, vendor compromise

Vulnerabilities: Limited visibility into vendor security practices

Explanation: Third-party systems introduce additional risk because they are outside direct control. A vulnerability in a vendor system could be exploited to access internal systems. Monitoring and control over these systems may be limited. While the impact is significant, it is slightly lower than direct internal system compromise.

3. Complete Risk Scores for each asset:

Risk Scoring Method:

Likelihood (1–5) × Impact (1–5)

The following risk scores are based on the assets identified in Question 3 and are calculated using the defined likelihood and impact scale:

- **Client Management System (Server/AWS)**

Likelihood: 4 (Probable)

Impact: 5 (Catastrophic)

Risk Score: 4 x 5 = 20 (Critical)

Justification: Likelihood is high due to exposure through VPN and cloud services, which increases the attack surface. Impact is catastrophic because this system supports core business operations and handles sensitive financial data.

- **Customer Financial Data (PII and credit cards)**

Likelihood: 5 (Frequent)

Impact: 5 (Catastrophic)

Risk Score: $5 \times 5 = 25$ (Critical)

Justification: Likelihood is very high due to stored sensitive financial and credit card data and excessive access permissions. The impact is catastrophic because a breach would result in severe financial losses, regulatory penalties, and reputational damage.

- **Shared Wireless Network**

Likelihood: 4 (Probable)

Impact: 4 (Significant)

Risk Score: $4 \times 4 = 16$ (Critical)

Justification: Likelihood is high due to shared access with an external organization and lack of segmentation. Impact is significant because unauthorized access could expose internal systems and communications.

- **Employee Laptops (Remote Devices)**

Likelihood: 4 (Probable)

Impact: 4 (Significant)

Risk Score: $4 \times 4 = 16$ (Critical)

Justification: Likelihood is high due to remote usage and exposure to unsecured networks. Impact is significant because compromised devices can provide attackers with access to internal systems.

- **VPN Infrastructure**

Likelihood: 3 (Occasional)

Impact: 5 (Catastrophic)

Risk Score: $3 \times 5 = 15$ (High)

Justification: Likelihood is moderate due to reliance on credentials and potential lack of MFA. Impact is catastrophic because the VPN provides direct access to internal systems.

- **Access Control System**

Likelihood: 5 (Frequent)

Impact: 5 (Catastrophic)

Risk Score: $5 \times 5 = 25$ (Critical)

Justification: Likelihood is very high because full access is granted to all users. The impact is catastrophic because this system controls access to all data and systems, thereby increasing the risk of insider threats.

- **New Employee Workstations**

Likelihood: 4 (Probable)

Impact: 3 (Moderate)

Risk Score: $4 \times 3 = 12$ (Medium)

Justification: Likelihood is high due to a lack of security configurations and monitoring. Impact is moderate because these systems are not critical, but still provide access to internal resources.

- **Cloud Infrastructure (AWS)**

Likelihood: 3 (Occasional)

Impact: 5 (Catastrophic)

Risk Score: $3 \times 5 = 15$ (High)

Justification: Likelihood is moderate due to potential misconfigurations in cloud services. The impact is catastrophic because cloud systems host critical applications and large volumes of data.

- **Authentication Systems**

Likelihood: 4 (Probable)

Impact: 5 (Catastrophic)

Risk Score: $4 \times 5 = 20$ (Critical)

Justification: Likelihood is high due to weak authentication controls and centralized access. The impact is catastrophic because a compromise would allow access to multiple systems.

- **Payment Processing System**

Likelihood: 4 (Probable)

Impact: 5 (Catastrophic)

Risk Score: $4 \times 5 = 20$ (Critical)

Justification: Likelihood is high due to stored credit card data and frequent transaction processing. The impact is catastrophic due to the risk of fraud, financial loss, and PCI compliance violations.

- **Vendor Applications**

Likelihood: 3 (Occasional)

Impact: 4 (Significant)

Risk Score: $3 \times 4 = 12$ (Medium)

Justification: Likelihood is moderate due to limited visibility into vendor security practices. The impact is significant because a vendor compromise could affect internal systems.

4. The matrix graph that was used to determine the risk score:

IMPACT	Catastrophic (5)	5	10	15	20	25
	Significant (4)	4	8	12	16	20
	Moderate (3)	3	6	9	12	15
	Low (2)	2	4	6	8	10
	Negligible (1)	1	2	3	4	5
		Improbable (1)	Remote (2)	Occasional (3)	Probable (4)	Frequent (5)
		LIKELIHOOD				